

Лекция 6. Расширенные ACL и разграничение межсетевого доступа

Цель лекции

Понимать, как extended ACL выбирает трафик по адресам, протоколам и портам

Объяснять, что обычная ACL является stateless и применяется в конкретном направлении

Настраивать именованные extended ACL для доступа пользователей к DMZ

Объяснять ключевое слово established и его ограничения

Проверять влияние ACL на DNS, HTTP, HTTPS, ICMP, traceroute и счётчики matches

Учебные вопросы

1. Селекция по Source/Destination IP, протоколам и портам
2. Ключевое слово established и проверка ACK/RST
3. established не является Stateful Firewall
4. Стратегии проектирования ACL и размещение ближе к Source

1. Расширенная ACL описывает трафик точнее стандартной

Extended ACL может учитывать Source IP, Destination IP, Protocol и L4 Port

Она позволяет разрешить один сервис и запретить другой между теми же подсетями

Например, пользователям можно разрешить HTTPS к WEB01, но запретить SSH к тому же серверу

Такая точность делает extended ACL базовым инструментом межсетевого разграничения на маршрутизаторах

Большая точность требует аккуратного порядка ACE, направления применения и тестирования

Extended ACL является stateless и направленной

Обычная extended ACL не хранит таблицу соединений

Она проверяет каждый пакет независимо

ACL действует только там, где применена: на

конкретном интерфейсе и в конкретном направлении

`interface Vlan10` и `ip access-group USERS\_IN in`

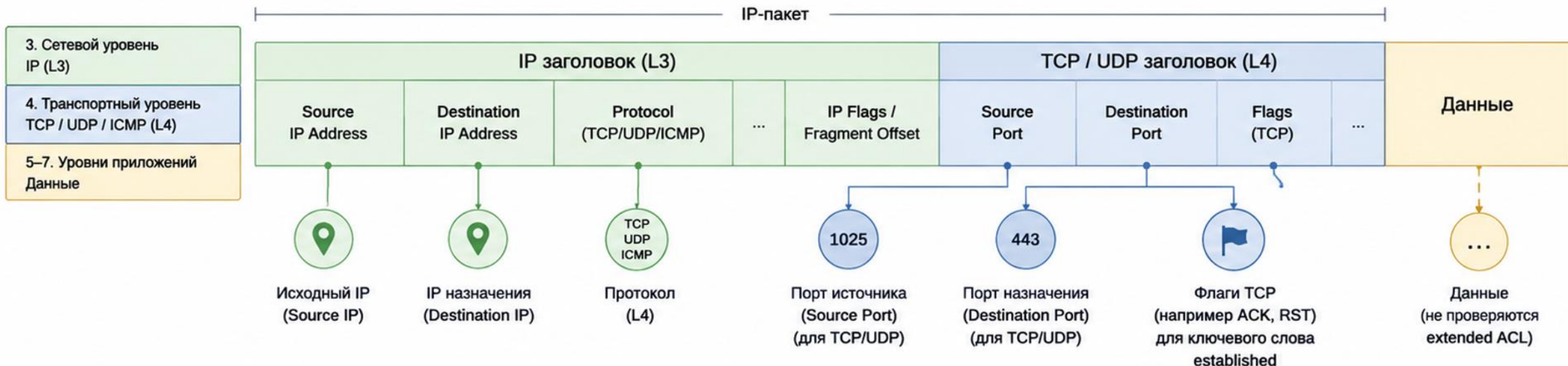
проверяют пакеты, входящие в маршрутизатор из
VLAN 10

Ответный трафик DMZ → VLAN 10 выходит через

Vlan10 и этой входящей ACL обычно не проверяется

Диаграмма: поля пакета, которые проверяет extended ACL

Extended ACL анализирует поля пакета 3-го и 4-го уровней модели OSI



Что может проверять extended ACL

- ✓ IP-адрес источника (Source IP)
- ✓ IP-адрес назначения (Destination IP)
- ✓ Протокол (IP / TCP / UDP / ICMP)
- ✓ Порт источника (Source Port) – для TCP/UDP
- ✓ Порт назначения (Destination Port) – для TCP/UDP
- ✓ Флаги TCP – для ключевого слова established (ACK, RST)

Тип протокола	Что можно проверить
ip	Source IP, Destination IP, Protocol (без портов и флагов)
tcp	Source IP, Destination IP, Protocol, Source Port, Destination Port, TCP Flags (established)
udp	Source IP, Destination IP, Protocol, Source Port, Destination Port
icmp	Source IP, Destination IP, ICMP Type, ICMP Code

Пример правила extended ACL и соответствие полям

```
permit tcp 192.168.10.0 0.00.0.255 host 192.168.30.10 eq 443
```

Source IP
192.168.10.0/24

Destination IP
192.168.30.10

Destination Port
443 (HTTPS)

Protocol
TCP



Пакет разрешается ТОЛЬКО если ВСЕ указанные поля совпадают с условиями правила ACL.



Ключевые выводы



Extended ACL фильтрует трафик точно по полям пакета.



ACL применима на интерфейсе и в конкретном направлении.



Порядок правил важен: первое совпадение определяет действие.



Всегда тестируйте: ping, traceroute, HTTP(S), DNS и другие сервисы.

Базовый синтаксис extended ACL

`ip access-list extended USERS\_IN` создаёт именованную расширенную ACL

Общая форма: `permit tcp SOURCE SOURCE_WILDCARD
DESTINATION DESTINATION_WILDCARD eq PORT`

В лабораторных политиках чаще проверяют destination port, например `eq 443` после адреса сервера

`permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 443` разрешает HTTPS к WEB01

Без финального разрешения сработает implicit deny

Source и Destination нельзя менять местами

После permit или deny сначала указывается источник трафика

Затем указывается назначение трафика

```
`permit tcp 192.168.10.0 ... host 192.168.30.10 eq 80`
```

означает трафик от пользователей к WEB01

Обратный трафик сервера к пользователю является другим направлением с другими полями

Ошибочная перестановка Source и Destination — частая причина нулевых matches

Операторы портов уточняют сервис

``eq`` означает равенство конкретному порту, например

``eq 443``

``neq`` означает любой порт, кроме указанного

``gt`` означает больше указанного номера порта

``lt`` означает меньше указанного номера порта

``range`` задаёт диапазон портов, например ``range 10000 20000``

Оператор порта относится к `source port` или `destination port` в зависимости от позиции в команде

Позиция оператора порта меняет смысл правила

```
`permit tcp 192.168.10.0 0.0.0.255 any eq 443`
```

проверяет destination port 443

Такое правило означает: клиенты VLAN 10 обращаются к HTTPS-сервисам

```
`permit tcp host 192.168.30.10 eq 443 192.168.10.0  
0.0.0.255`
```

 проверяет source port 443

Такое правило похоже на ответ сервера с TCP source port 443 клиентской сети

Для текущей лекции основной рабочий вариант — фильтрация по destination port

Протоколы IP, TCP, UDP и ICMP проверяются по-разному

`ip` означает любой IP-трафик без уточнения L4-порта

`tcp` позволяет использовать номера TCP-портов и ключевое слово `established`

`udp` используется для DNS, DHCP, NTP и других UDP-сервисов

`icmp` фильтрует диагностические сообщения, например `echo` и `unreachable`

Если выбрать `ip` вместо `tcp`, оператор `eq 443` использовать нельзя`

Практический сценарий USERS_IN

VLAN 10 USERS: 192.168.10.0/24

DMZ: 192.168.30.0/24

WEB01: 192.168.30.10

DNS01: 192.168.30.53

Задача: разрешить пользователям только нужные сервисы DMZ и запретить остальные DMZ-сервисы

Политика доступа USERS → DMZ

USERS → DNS01 UDP/53: permit

USERS → DNS01 TCP/53: permit

USERS → WEB01 TCP/80: permit

USERS → WEB01 TCP/443: permit

USERS → другие DMZ-сервисы: deny

USERS → остальные сети: permit

USERS_IN: разрешаем DNS к DNS01

```
R1(config)# ip access-list extended USERS_IN
```

```
R1(config-ext-nacl)# 10 remark DNS to DNS01
```

```
R1(config-ext-nacl)# 20 permit udp 192.168.10.0  
0.0.0.255 host 192.168.30.53 eq 53
```

```
R1(config-ext-nacl)# 30 permit tcp 192.168.10.0 0.0.0.255  
host 192.168.30.53 eq 53
```

UDP/53 покрывает обычные DNS-запросы, TCP/53
нужен для части нормальных DNS-сценариев

USERS_IN: разрешаем HTTP и HTTPS к WEB01

```
R1(config-ext-nacl)# 40 remark WEB access
```

```
R1(config-ext-nacl)# 50 permit tcp 192.168.10.0 0.0.0.255  
host 192.168.30.10 eq 80
```

```
R1(config-ext-nacl)# 60 permit tcp 192.168.10.0 0.0.0.255  
host 192.168.30.10 eq 443
```

Оператор `eq 80` и `eq 443` находится после destination, значит проверяется destination port SSH, SMB и другие сервисы WEB01 этими строками не разрешаются

SERS_IN: блокируем остальные DMZ-сервисы и разрешаем остально

```
R1(config-ext-nacl)# 70 remark Block other access to DMZ
```

```
R1(config-ext-nacl)# 80 deny ip 192.168.10.0 0.0.0.255  
192.168.30.0 0.0.0.255
```

```
R1(config-ext-nacl)# 90 remark Permit remaining USERS  
traffic
```

```
R1(config-ext-nacl)# 100 permit ip 192.168.10.0 0.0.0.255  
any
```

Строка 80 должна стоять до финального permit, иначе запрет DMZ не сработает

USERS_IN применяют на входе пользовательской VLAN

```
R1(config)# interface Vlan10
```

```
R1(config-if)# ip access-group USERS_IN in
```

VLAN10 → Vlan10 IN → Routing → DMZ

Расширенную ACL размещаем рядом с source, поэтому трафик фильтруется при входе из VLAN 10

Так запрещённый трафик не уходит дальше в routed-инфраструктуру

Проверка применения ACL на интерфейсе

R1# show ip interface Vlan10

Характерная строка: `Inbound access list is USERS\_IN`

Характерная строка: `Outgoing access list is not set`

Если inbound access list пустой, ACL создана, но не применена

Если ACL применена out вместо in, тесты будут вести себя иначе

show ip access-lists показывает правила и matches

```
R1# show ip access-lists USERS_IN
```

```
Extended IP access list USERS_IN
```

```
20 permit udp 192.168.10.0 0.0.0.255 host 192.168.30.53  
eq domain (18 matches)
```

```
50 permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10  
eq www (7 matches)
```

```
60 permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10  
eq 443 (12 matches)
```

```
80 deny ip 192.168.10.0 0.0.0.255 192.168.30.0 0.0.0.255  
(3 matches)
```

matches превращают тесты в доказательство

matches показывает количество пакетов, совпавших с конкретной ACE

После DNS-запроса должен увеличиться счётчик на UDP/53 или TCP/53

После открытия HTTP должен увеличиться счётчик на TCP/80

После попытки SSH к WEB01 должен увеличиться счётчик на deny к DMZ

Если счётчик не меняется, проверяют интерфейс, направление, source IP и порядок ACE

Таблица тестов USERS_IN

USERS → DNS01 UDP/53: разрешено

USERS → DNS01 TCP/53: разрешено

USERS → WEB01 TCP/80: разрешено

USERS → WEB01 TCP/443: разрешено

USERS → WEB01 TCP/22: запрещено

USERS → другой DMZ-сервис: запрещено

USERS → разрешённая внешняя сеть: разрешено

Схема: доступ VLAN 10 к сервисам DMZ через extended ACL

Расширенный ACL на маршрутизаторе разрешает только нужные сервисы из VLAN 10 в DMZ



✓ Разрешено (пример)

- DNS (TCP/UDP 53) к 192.168.30.53
- HTTP (TCP 80) к 192.168.30.10
- HTTPS (TCP 443) к 192.168.30.10



Трафик из VLAN 10 в DMZ

ПРОВЕРЯЕТСЯ ACL USERS_IN



✗ Запрещено (остальной доступ к DMZ)

- SMB (TCP 445)
- RDP (TCP 3389)
- Любые другие протоколы и порты

Пример extended ACL: USERS_IN (порядок правил имеет значение)

№	Действие	Протокол	Источник	Источник Wildcard	Назначение	Назначение Wildcard	Порт назначения	Описание
10	permit	udp	192.168.10.0	0.0.0.255	host 192.168.30.53	0.0.0.0	eq 53	Разрешить DNS (UDP)
20	permit	tcp	192.168.10.0	0.0.0.255	host 192.168.30.53	0.0.0.0	eq 53	Разрешить DNS (TCP)
30	permit	tcp	192.168.10.0	0.0.0.255	host 192.168.30.10	0.0.0.0	eq 80	Разрешить HTTP
40	permit	tcp	192.168.10.0	0.0.0.255	host 192.168.30.10	0.0.0.0	eq 443	Разрешить HTTPS
50	deny	ip	192.168.10.0	0.0.0.255	192.168.30.0	0.0.0.255	any	Запретить остальной доступ к DMZ
100	permit	ip	192.168.10.0	0.0.0.255	any	0.0.0.0	any	Разрешить остальной трафик из VLAN 10
implicit	deny	ip	any	any	any	any	any	Неявный запрет всего остального

Применение ACL на маршрутизаторе



```
interface Vlan10  
ip access-group USERS_IN in
```

Проверяет входящие пакеты из VLAN 10

i Важно помнить

- ACL является stateless – проверяется каждый пакет отдельно
- Ответный трафик из DMZ к VLAN 10 не проверяется этой входящей ACL
- Размещайте ACL ближе к источнику трафика (VLAN 10)
- Проверяйте счётчики правил: `show access-lists USERS_IN`



Как работает схема



Пользователи VLAN 10 иницируют соединение



Маршрутизатор проверяет пакеты по ACL USERS_IN (in на Vlan10)



Если правило разрешает – пакет отправляется в DMZ



Если правило запрещает – пакет отбрасывается и не попадает в DMZ



Сервер в DMZ отвечает (ответный трафик не проверяется этой ACL)

DNS требует разрешить UDP 53 и TCP 53

DNS (Domain Name System) чаще начинает обычный запрос по UDP/53

TCP/53 используется для передачи зон и когда ответ не помещается в UDP

Крупные ответы возможны, например, из-за DNSSEC

Рабочим станциям обычно не нужна передача зон, но

TCP-запросы DNS всё равно могут потребоваться

Для корпоративного DNS обычно разрешают и UDP/53, и TCP/53 к DNS-серверу

ICMP нужен не только для ping

ICMP Echo Request используется командой ping для запроса

ICMP Echo Reply используется для ответа на ping

ICMP Time Exceeded нужен traceroute для отображения промежуточных узлов

ICMP Destination Unreachable помогает понять, что сеть, порт или хост недоступны

Полный запрет ICMP усложняет диагностику и может ломать нормальное поведение сети

ICMP-правила зависят от интерфейса и направления

ACL in на Guest SVI видит запросы от гостевых клиентов

Ответы к гостевым клиентам через тот же SVI обычно проходят в направлении out

Поэтому `echo-reply` не всегда нужен в той же входящей ACL, где запрещается `echo`

`permit icmp ... echo-reply` разрешает подходящие Echo Reply, но не выполняет stateful-проверку

Сначала указывают место применения ACL, затем выбирают ICMP-типы

Пример ICMP-политики для гостевой VLAN

ACL на входе Guest VLAN может запретить гостям инициировать ping в DMZ

Пример: ``deny icmp 192.168.40.0 0.0.0.255 192.168.30.0 0.0.0.255 echo``

Если отдельная ACL применяется к направлению в сторону Guest VLAN, в ней можно разрешить echo-reply

Для диагностики также могут понадобиться time-exceeded и unreachable

Без указания интерфейса и направления ICMP-политику легко понять неправильно

tracert и traceroute используют разные probe-пакеты

Windows tracert обычно использует ICMP Echo

Классический Linux/Unix traceroute часто использует UDP

Cisco IOS traceroute обычно использует UDP

Промежуточные маршрутизаторы отвечают ICMP Time Exceeded

Конечный узел при UDP-варианте может вернуть ICMP Destination Unreachable — Port Unreachable

Разрешение только echo и echo-reply не гарантирует работу traceroute

2. established смотрит на TCP-флаги ACK или RST

Ключевое слово established применяется только к TCP-правилам

Оно разрешает TCP-сегменты, где установлен флаг ACK или RST

Идея: разрешить обратный трафик для соединений, начатых изнутри

Пример: ``permit tcp any 192.168.10.0 0.0.0.255 established``

Это старая статическая техника, а не полноценное отслеживание состояния

Как `established` может применяться

Клиент из VLAN 10 отправляет исходящий TCP SYN к внешнему серверу

Сервер отвечает SYN/ACK, и в ответном TCP-сегменте установлен ACK

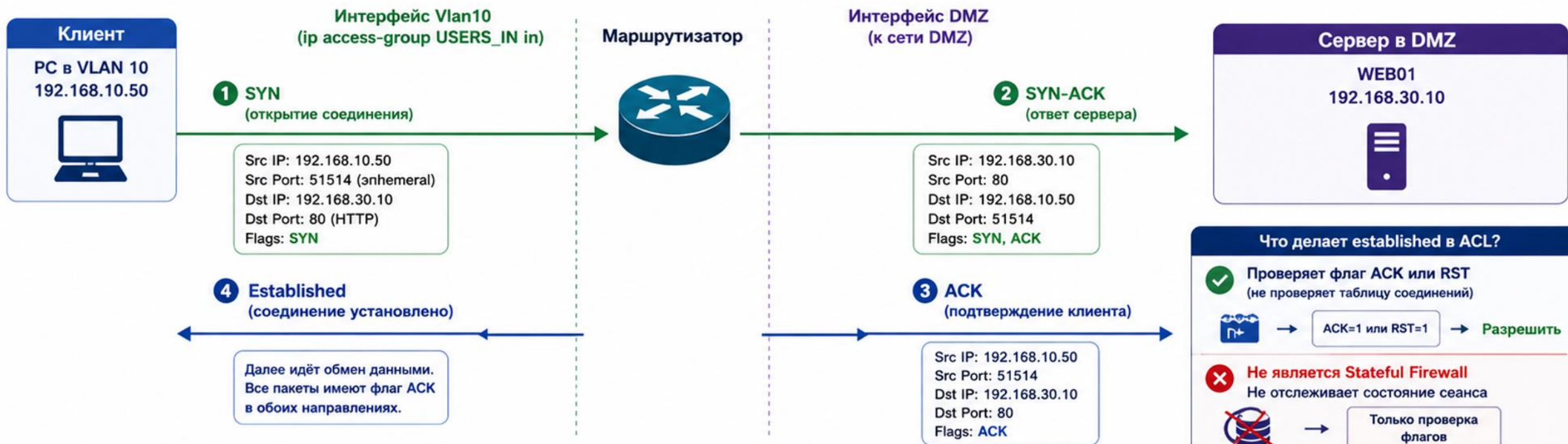
Правило `established` может разрешить такой обратный TCP-трафик

Для UDP и ICMP ключевое слово `established` не работает

В новых проектах эту задачу чаще решают `stateful firewall`, а не статической ACL

Диаграмма: TCP SYN и ответный трафик с established

Как работает key-word established в extended ACL



Что делает established в ACL?

- ✓ Проверяет флаг ACK или RST (не проверяет таблицу соединений)
ACK=1 или RST=1 → **Разрешить**
- ✗ Не является Stateful Firewall
Не отслеживает состояние сеанса
Только проверка флагов

Пример работы ACL с established

Входящая ACL на Vlan10 (в сторону маршрутизатора)

№	Правило ACL	Действие
10	permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 80	Разрешить SYN (к веб-серверу)
20	permit tcp any any established	Разрешить ответный трафик с флагом ACK/RST
30	deny ip any any	Запретить остальной трафик
implicit deny	deny ip any any	Запретить всё остальное

Как обрабатываются пакеты

- 1 SYN от клиента → правило 10 (**permit**)
- 2 SYN-ACK от сервера → правило 20 (**established**)
флаг ACK устанавливается → разрешается
- 3 ACK от клиента → правило 20 (**established**)
- 4 Дальнейшие данные в обе стороны → правило 20 (**established**)

Типичные флаги TCP

Флаг	Бит	Назначение
SYN	0x02	Установка соединения (открытие)
ACK	0x10	Подтверждение получения
RST	0x04	Сброс соединения
FIN	0x01	Завершение соединения

Ключевые выводы

- ✓ Клиент начинает соединение пакетом SYN.
- ✓ Сервер отвечает SYN-ACK.
- ✓ Клиент подтверждает ACK.
- ✓ Дальнейший трафик содержит ACK в обоих направлениях.
- ✓ Правило с established разрешает только пакеты с флагом ACK или RST.
- ✓ Это упрощает политику и позволяет возвращающийся трафик без явных правил для каждого порта.



Важно:
established ≠ отслеживание соединений.
Это только проверка флагов ACK или RST.



Размещайте ACL ближе к источнику (Vlan10 IN), чтобы блокировать нежелательный трафик до пересечения сети.



Проверяйте счётчики правил:
show access-lists USERS_IN



Тестируйте: ping, traceroute,
HTTP/HTTPS, DNS.

3. established не делает ACL stateful firewall

Stateful Firewall хранит таблицу соединений и понимает контекст обмена

ACL с established не хранит connection table

Она не знает, действительно ли ранее был исходящий SYN

Она проверяет только TCP-флаги ACK или RST

Пакет с ACK может совпасть с правилом, даже если реального разрешённого соединения не было

Ограничения extended ACL нужно проговаривать студентам

Extended ACL не заменяет firewall-политику предприятия

Она не анализирует приложения и пользователей

Она не решает stateful-задачи для UDP и ICMP

Она не защищает автоматически от асимметричных путей

Её сила — простая, понятная и проверяемая фильтрация на маршрутизаторе

4. Расширенные ACL размещают ближе к источнику

Extended ACL знает Source, Destination, Protocol и Port
Поэтому ненужный трафик можно отбросить уже на gateway исходной VLAN

Это экономит пропускную способность и упрощает понимание политики

В сценарии USERS_IN ACL ставится на `interface Vlan10` в направлении `in`

Размещение всегда проверяют по фактическому пути пакета

Направление in или out выбирается относительно интерфейса

`in` означает, что пакет входит в маршрутизатор через интерфейс

`out` означает, что пакет выходит из маршрутизатора через интерфейс

Для `interface Vlan10` направление `in` видит запросы пользователей до маршрутизации

Для ответа DMZ → USERS тот же интерфейс Vlan10 будет направлением `out`

Неверное направление — одна из самых частых причин нулевых counters

На интерфейс обычно ставят одну IPv4 ACL на направление

Классическая логика Cisco IOS: один IPv4 ACL inbound и один IPv4 ACL outbound на интерфейс

Если требований несколько, их объединяют в один согласованный список ACE

Нельзя рассчитывать, что несколько отдельных ACL последовательно применятся к одному направлению

Поэтому policy design делают заранее: разрешения, запреты, финальное поведение

Перед применением проверяют, не заменит ли новая ACL существующую политику

ACL на SVI не фильтрует трафик внутри одной VLAN

WEB01 192.168.30.10 и DB01 192.168.30.20 находятся в VLAN 30

Трафик WEB01 → L2 Switch → DB01 не проходит через SVI/gateway

`ip access-group` на `interface Vlan30` не увидит такой внутривлановый обмен

Для фильтрации внутри одной VLAN нужны другие подходы

Обзорные варианты: host firewall, отдельные VLAN/subnets, PACL, VACL, Private VLAN

remark делает ACL читаемой

`remark` добавляет комментарий внутри ACL

Пример: `10 remark DNS to DNS01`

Комментарии помогают связать ACE с требованием политики

remark не фильтрует трафик и не влияет на counters

В длинных ACL без remark сложно понять, зачем была добавлена конкретная строка

Проверка TCP-порта и HTTPS — разные задачи

`Test-NetConnection 192.168.30.10 -Port 443` проверяет TCP-доступность порта в Windows

`nc -vz 192.168.30.10 443` проверяет TCP-порт в Linux

Успешное TCP-подключение не доказывает TLS handshake, сертификат или ответ приложения

HTTPS проверяют браузером или `curl -k https://192.168.30.10/`

HTTP проверяют `curl http://192.168.30.10/`

Успешный ping не доказывает работу TCP-сервиса

Типовые ошибки extended ACL

Source и Destination указаны наоборот

Забыли permit для DNS, и web-доступ по имени перестал работать

ACL создана, но забыли применить ip access-group

ACL применена out вместо in или на неверном интерфейсе

В конце отсутствует нужный permit, и сработал implicit deny

established принят за полноценный stateful firewall

Стратегия размещения extended ACL

Размещайте ACL там, где нужно остановить нежелательный трафик как можно раньше



Главные принципы

- 1 Размещайте ACL ближе к источнику трафика
- 2 Фильтруйте нежелательный трафик на входе
- 3 Учитывайте направление трафика
- 4 Проверяйте и тестируйте правила

Почему ближе к источнику?



Экономия полосы пропускания



Повышение безопасности



Меньше нагрузки на сеть



Защита ресурсов назначения

Куда обычно размещают extended ACL

- ✓ На интерфейсе, где трафик ВХОДИТ в сеть источника
- ✓ На подинтерфейсе VLAN (SVI) или физическом интерфейсе
- ✓ В правильном направлении: IN к источнику, OUT от источника
- ✓ Не забывайте про ответы (обратный трафик)



✓ ПРАВИЛЬНО: ближе к источнику (IN)

Пользовательская сеть (VLAN 10)
192.168.10.0/24



ACL USERS_IN применяется IN на интерфейсе Vlan10 (ближе к источнику)

IN
Интерфейс Vlan10



OUT
Интерфейс в DMZ

DMZ сеть
192.168.30.0/24



Пример ACL USERS_IN

```
permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 80
permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 443
deny ip 192.168.10.0 0.0.0.255 192.168.30.0 0.0.0.255
permit ip 192.168.10.0 0.0.0.255 any
```

- ✓ Нежелательный трафик блокируется сразу
- ✓ Экономия полосы и ресурсов сети
- ✓ Снижается нагрузка на маршрутизатор и каналы связи

Как работает

Пользователь из VLAN 10 отправляет пакет



ACL проверяет пакет на входе в маршрутизатор



Если разрешено – пакет идёт дальше к DMZ



Если запрещено – пакет отбрасывается сразу

✗ НЕПРАВИЛЬНО: ближе к назначению (OUT)

Пользовательская сеть (VLAN 10)
192.168.10.0/24



ACL применяется OUT на интерфейсе в DMZ (далеко от источника)

IN
Интерфейс Vlan10



OUT
Интерфейс в DMZ

DMZ сеть
192.168.30.0/24



Пример ACL OUT_DMZ

```
permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 80
permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 443
deny ip 192.168.10.0 0.0.0.255 192.168.30.0 0.0.0.255
permit ip 192.168.10.0 0.0.0.255 any
```

- ✗ Нежелательный трафик проходит через сеть
- ✗ Тратится полоса пропускания
- ✗ Повышенная нагрузка и риски безопасности

Как это работает (плохо)

Пользователь из VLAN 10 отправляет пакет



Пакет проходит через маршрутизатор и каналы связи



ACL проверяет только на выходе в DMZ



Если запрещено – пакет отбрасывается, но ресурсы уже потрачены

Направление применения ACL

IN – проверяет входящие пакеты на интерфейсе



OUT – проверяет исходящие пакеты с интерфейса



Выбирайте направление в зависимости от того, где находится источник трафика, который нужно контролировать.

Примеры размещения

Сценарий	Где разместить ACL
Пользователи VLAN → DMZ	IN на интерфейсе VLAN
Пользователи VLAN → Интернет	OUT на интерфейсе к Интернет
Интернет → DMZ (публикация сервера)	IN на интерфейсе к DMZ
DMZ → Внутренняя сеть	OUT на интерфейсе к внутренней сети

Чек-лист перед применением ACL



- ✓ Определил источник трафика и назначение
- ✓ Выбрал интерфейс и направление (IN/OUT)
- ✓ Разместил ACL ближе к источнику
- ✓ Проверил порядок правил (открытые сверху)
- ✓ Добавил разрешающие правила для нужных сервисов
- ✓ Проверил счётчики: show access-lists <имя>



Главное правило:

Блокируйте трафик как можно раньше, как можно ближе к источнику!



Безопаснее



Эффективнее



Экономичнее



Проще в управлении

Мини-сценарий политики USERS/GUEST/DMZ

VLAN 10 USERS может обращаться к WEB01 в DMZ по HTTP и HTTPS

VLAN 40 GUEST не может обращаться к внутренним серверам

Обе VLAN должны иметь доступ к DNS-серверу
ICMP echo из гостевой сети к DMZ запрещён, но
диагностические сообщения не блокируются
полностью

После настройки проверяют разрешённые и
запрещённые сценарии отдельно

Порядок правил в extended ACL проектируют как политику

Сначала записывают точные разрешения к необходимым сервисам

Затем добавляют точные запреты к защищённым зонам

После этого решают, нужен ли финальный permit для остального трафика источника

`permit ip any any` фактически отключает implicit deny для всего оставшегося IPv4-трафика

Каждая строка должна соответствовать одному понятному требованию безопасности

ACL и return traffic требуют отдельной проверки

Обратное разрешающее правило требуется только в той ACL, через которую действительно проходит ответный пакет

Не нужно механически дублировать каждое правило в обратном направлении

Сначала определяют маршрут запроса и маршрут ответа

Затем определяют интерфейсы и направления ACL для каждой половины обмена

Для UDP нет established, поэтому ответы DNS или NTP должны быть учтены политикой

Дополнительно: асимметричная маршрутизация

Асимметричная маршрутизация — запрос и ответ проходят через разные маршрутизаторы или интерфейсы

Конкретная stateless ACL может видеть только одну половину обмена

Это допустимо, если правила на обоих путях согласованы

Для stateful firewall асимметрия часто критичнее, потому что устройство может не увидеть начало соединения

При диагностике проверяют counters на обоих

Практический порядок проверки extended ACL

1. Проверить, что ACL применена: ``show ip interface Vlan10``
2. Выполнить разрешённый DNS, HTTP или HTTPS-тест
3. Выполнить запрещённый тест, например USERS → WEB01 TCP/22
4. Проверить ``show ip access-lists USERS_IN`` и matches
5. Если counters не меняются, проверить source IP, интерфейс, направление и порядок ACE

Итоги лекции

Extended ACL проверяет Source, Destination, Protocol и Ports

Порядок ACE определяет, какое правило сработает первым

Направление `in` или `out` выбирается относительно интерфейса маршрутизатора

Extended ACL обычно размещают ближе к Source, потому что она точно определяет нежелательный трафик

DNS, ICMP и traceroute нужно учитывать осознанно, а не блокировать всё подряд

Контрольные вопросы

Какие поля может анализировать Extended ACL?

Почему Source и Destination нельзя менять местами?

Где указывается Source Port, а где Destination Port?

Чем `ip`, `tcp`, `udp` и `icmp` отличаются в ACL?

Почему Extended ACL обычно размещают ближе к Source?

Что означает направление `in` и `out`?

Что проверяет `established`?

Почему `established` не является Stateful Firewall?

Почему ACL на SVI не фильтрует трафик между двумя узлами одной VLAN?